

PLANO DE RESPOSTA A INCIDENTES

Time: Blue Team

Nº Incidente: INC-2024-001

Classificação: ☒ Crítico ☐ Alto ☐ Médio ☐ Baixo

Data/Hora: 2026-06-20 14:32

Integrantes: Flávio, Anderson, Kaio, Paula, Erick e Alan

1. DESCRIÇÃO DO INCIDENTE

Rota afetada: GET /orders/:id

IP(s) de origem: 203.0.113.77 (ataque principal), 203.0.113.78 e 203.0.113.79 (tentativa de bypass do rate limiting)

Período: 14:32 até 14:36 (UTC)

Total de requisições detectadas: 650 (600 do IP principal + 25 + 25 dos IPs de bypass)

2. LINHA DO TEMPO

[14:32:00] Primeiros acessos anômalos no log (enumeração sequencial de /orders/:id, sem header x-user-id, User-Agent "python-requests")

[14:32:00 a 14:35:15] Pico de requisições (~420/min, ~7 req/s sustentado)

[14:32:02] Padrão identificado pela equipe (volume cruza o limiar de 20 req/min de um único IP — ver relatório-analise.md)

[14:35:15] Contenção aplicada (rate limiting habilitado no NGINX)

Tempo de detecção: ~0,03 minutos (2 segundos) PARA O PADRÃO FICAR VISÍVEL NO LOG.

Ressalva: esse número só é real se houver monitoramento ativo/alertas (ver seção 7). Sem alerta automático, o MTTD efetivo depende de quando um analista abre o log manualmente — podendo ser horas.

3. IMPACTO

Pedidos expostos: 8 de 8 (100% da base — ids 1 a 8)

Usuários afetados: 5 (ids 101, 102, 103, 104, 105)

Dados pessoais expostos: ☒ Sim ☐ Não

Categorias (se sim): ☐ Nome ☐ Endereço ☒ Dados financeiros (valor do pedido) ☒ Outro: histórico/status de compras, produto adquirido

4. CONTENÇÃO

Ação imediata tomada:

- ☐ Bloqueio de IP
- ☒ Rate limiting ativado
- ☐ Rota desabilitada
- ☒ Equipe notificada

Descrição: ativação de `limit_req_zone` no NGINX (`proxy/nginx.conf`) limitando requisições por IP na rota `/orders/`. Reduziu ~81% das requisições subsequentes do atacante (263 de 325 retornaram HTTP 429), mas não eliminou o ataque: ele é por IP, e o atacante demonstrou conseguir cota nova trocando de IP. A correção definitiva (fora do escopo do hardening de rede) é adicionar verificação de propriedade (`ownership check`) no endpoint `GET /orders/:id`.

5. IMPACTO FINANCEIRO (LGPD — Art. 52)

Faturamento anual da empresa (estimado): R\$ 30.000.000,00 *(valor ilustrativo para fins didáticos)*

Multa máxima (2% do faturamento, limite R\$ 50M): R\$ 600.000,00

Estimativa de custo por titular afetado: R\$ 180,00 *(referência ilustrativa de custo médio por registro vazado — notificação, suporte, forense)*

Custo total estimado do incidente: R\$ 900,00 (5 titulares × R\$ 180) + custos de resposta (forense, jurídico, comunicação) — **muito inferior ao teto de multa de R\$ 600.000,00**, o que reforça que o maior risco aqui não é o valor imediato vazado, mas o **precedente de exposição de 100% da base** caso o atacante real tivesse explorado em escala maior antes da contenção.

6. OBRIGAÇÕES LEGAIS

Houve dado pessoal exposto? ☒ Sim ☐ Não

Se SIM:

- ☒ Comunicar à ANPD em até 72h (Art. 48, LGPD — prazo conta a partir do conhecimento do incidente pelo controlador)
- ☒ Notificar titulares afetados (os 5 usuários donos dos pedidos 1–8)
- ☒ Registrar no Relatório de Impacto (RIPD)

7. LIÇÕES APRENDIDAS

O que a API deveria ter para impedir esse ataque?

- Verificação de `ownership` no `GET /orders/:id` (comparar o dono do pedido com o usuário autenticado via `x-user-id`) — corrige a causa raiz (BOLA), o rate limiting apenas mitiga o volume.
- IDs não sequenciais/não previsíveis (UUID) para dificultar enumeração.
- Autenticação real (token assinado) em vez de um header `x-user-id` livre, que qualquer cliente pode forjar.

- Rate limiting já ajuda a reduzir o dano (~81% bloqueado neste caso), mas deve ser complementado por bloqueio adaptativo (ex.: IP com taxa de erro 404 muito alta = comportamento de varredura).

(Extra) Critério de alerta automático proposto:

"Disparar alerta quando um único IP enviar ≥ 20 requisições/minuto à rota /orders/, OU quando a razão (IDs distintos acessados $\div$ total de requisições) desse IP for $\geq 0,9$ em uma janela de 1 minuto (assinatura de varredura sequencial, distinta do padrão de um usuário real que sempre acessa os mesmos poucos IDs)."